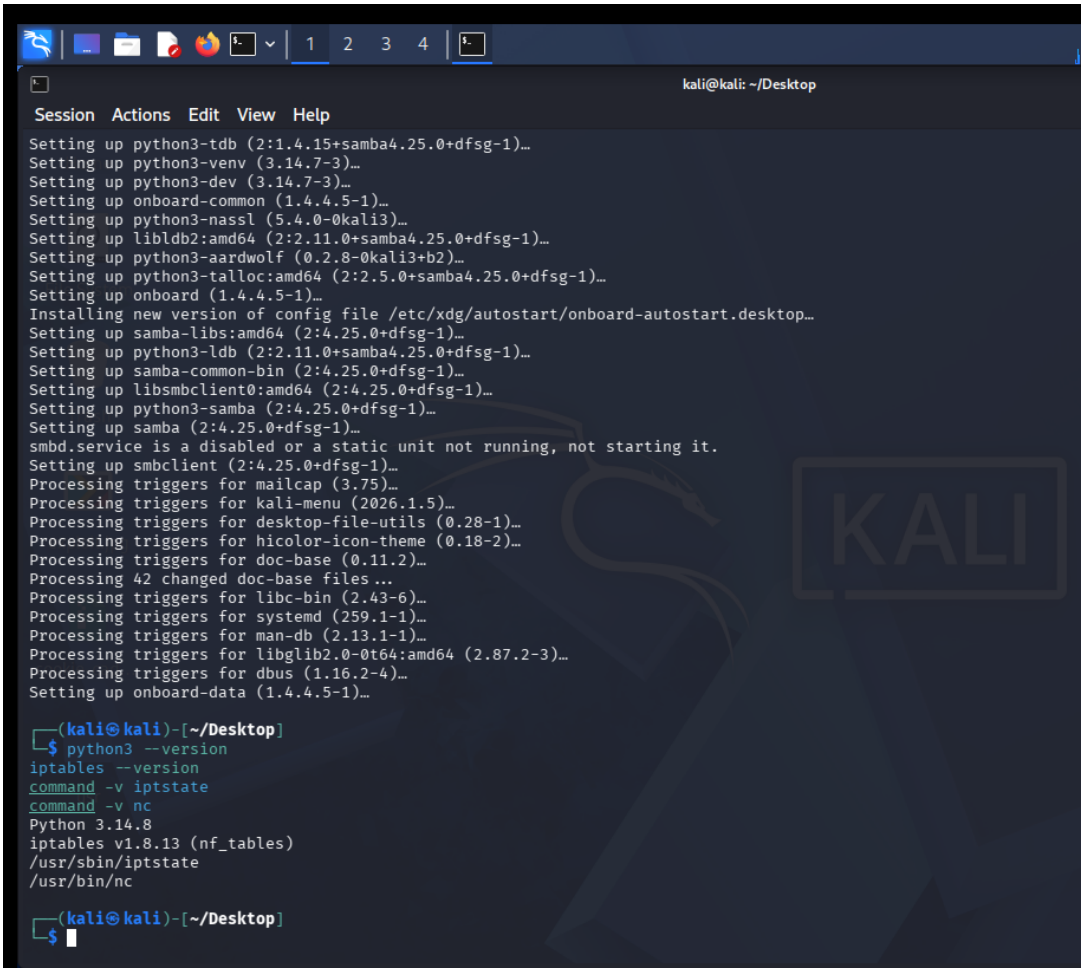
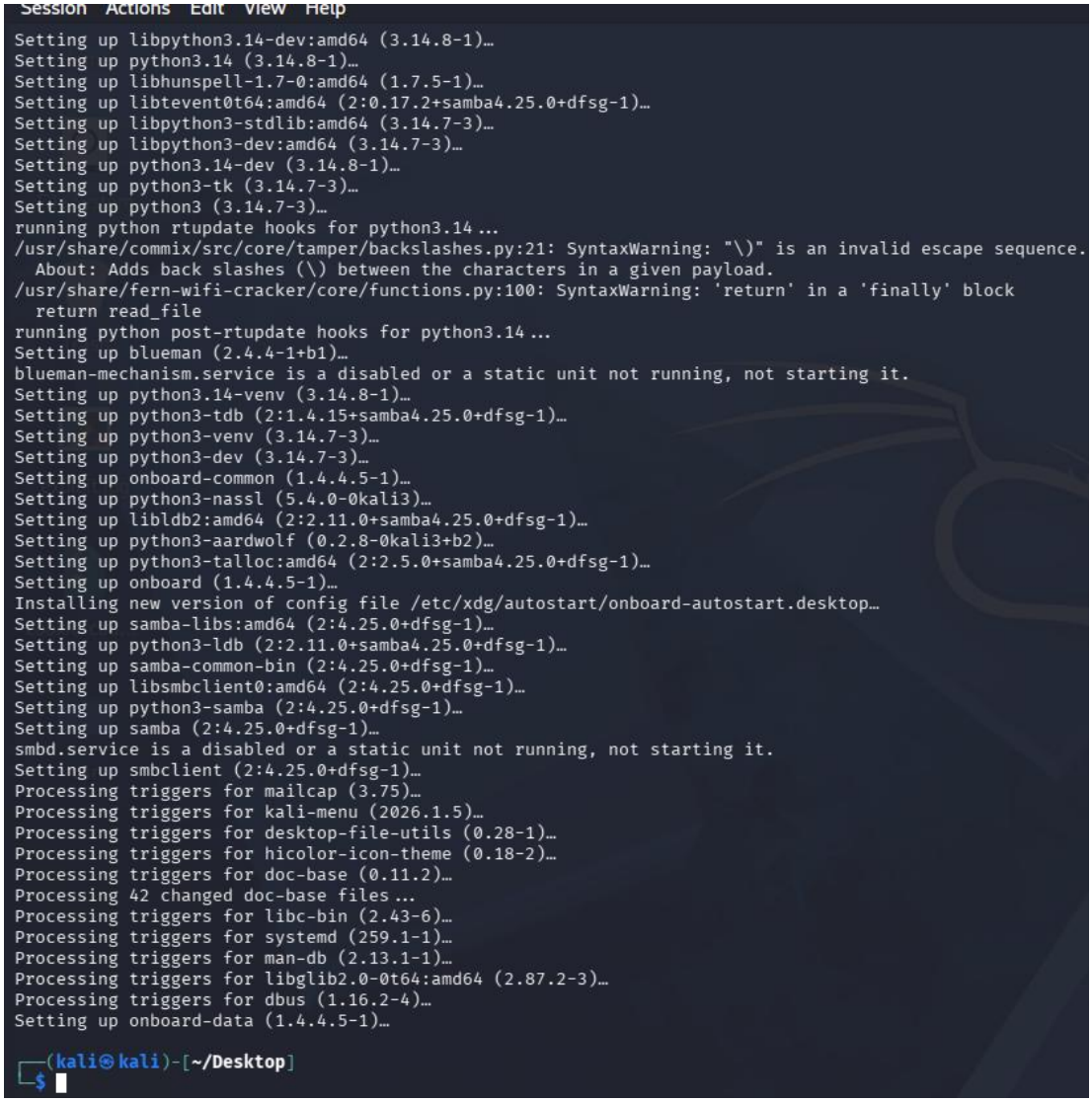
Trần Tăng Trường Thịnh 2387701939

BÀI 6: BẢO VỆ MÁY CHỦ VÀ TỰ ĐỘNG HÓA CÁC YÊU CẦU WEB

6.1 CHUẨN BỊ



Hình 1: Kiểm tra cài đặt trên máy A



Hình 2: Kiểm tra cài đặt trên máy B

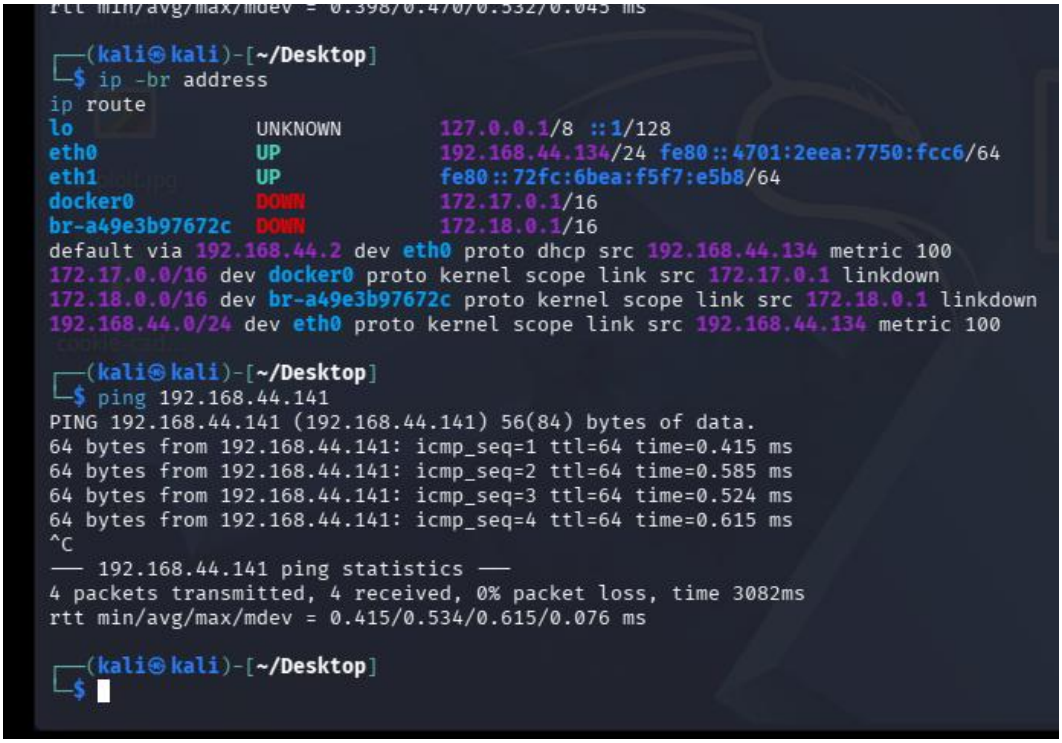
6.2 BẢO VỆ MÁY CHỦ THÔNG QUA IPTABLES VÀ IPTSTATE

Mục tiêu: Cấu hình tường lửa trạng thái (Stateful Firewall) bằng iptables để bảo vệ máy chủ và giám sát các phiên kết nối mạng bằng iptstate.

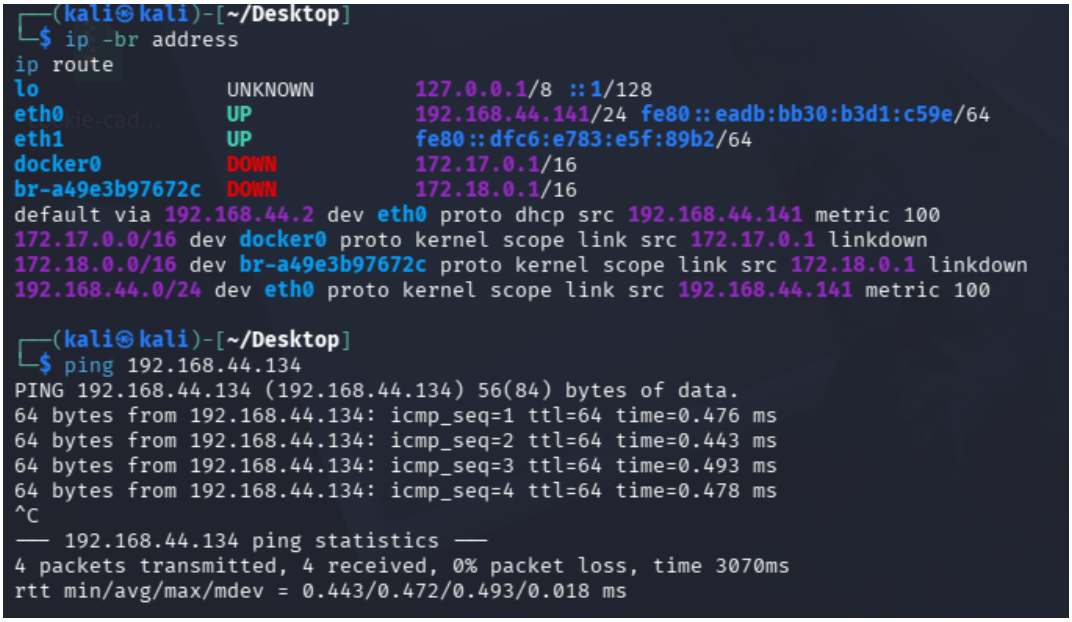
Các bước thực hiện:

1. Kiểm tra kết nối mạng và dịch vụ lắng nghe ban đầu bằng netcat trên cổng TCP 9999 giữa 2 máy.
2. Tạo chuỗi riêng LAB06_IN trên máy chủ (Máy A) với chính sách: chặn gói không hợp lệ (INVALID), cho phép kết nối đã thiết lập (ESTABLISHED,RELATED), cho phép Ping (ICMP), chỉ mở cổng web 8080 và chặn toàn bộ lưu lượng còn lại (DROP).
3. Kiểm thử cơ chế chặn: Máy B ping thành công nhưng kết nối cổng 9999 bị timeout, bộ đếm quy tắc DROP tăng gói tin.
4. Mở cổng 9999 có chọn lọc, thiết lập kết nối Netcat và dùng iptstate cùng lệnh ss để giám sát kết nối ở trạng thái ESTABLISHED.
5. Xóa quy tắc mở cổng 9999 để kiểm chứng tính năng lọc trạng thái (Stateful): kết nối cũ vẫn duy trì bình thường, trong khi các kết nối mới (NEW) bị chặn hoàn toàn.

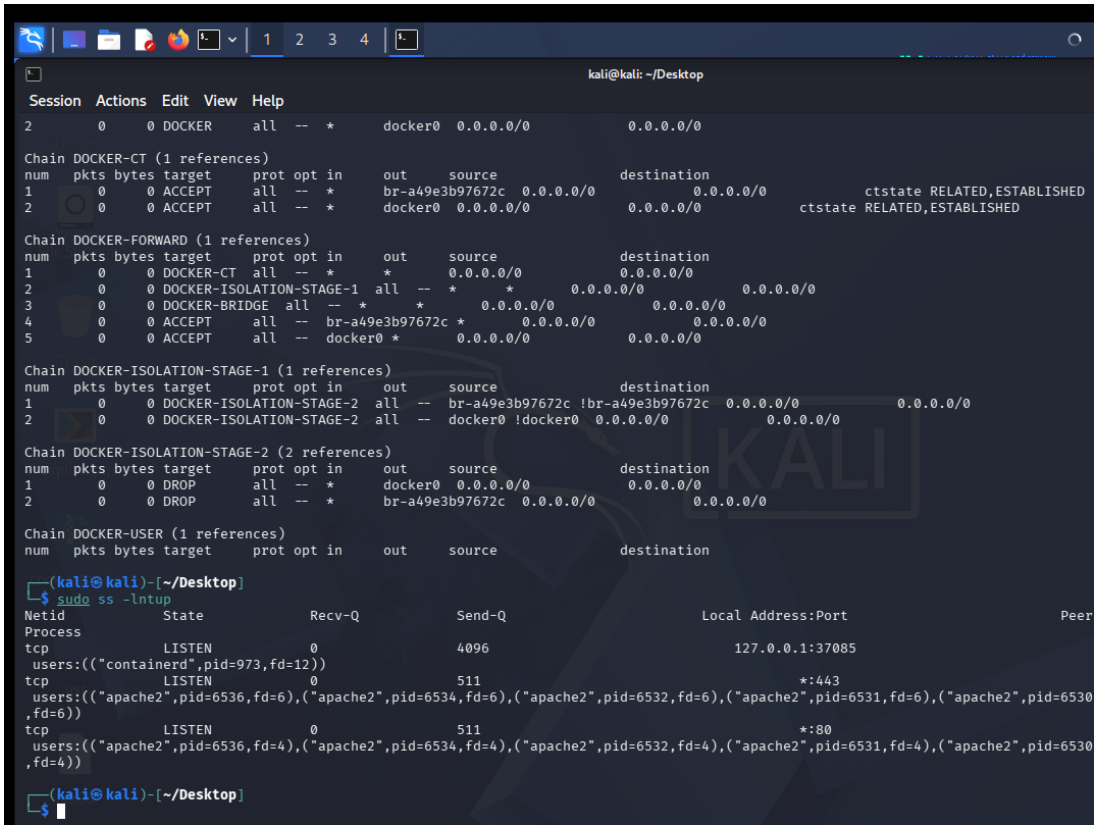
Kết quả: Xây dựng thành công tường lửa lọc gói theo trạng thái kết nối, kiểm soát truy cập cổng dịch vụ chặt chẽ và giám sát trực quan các phiên kết nối thời gian thực.



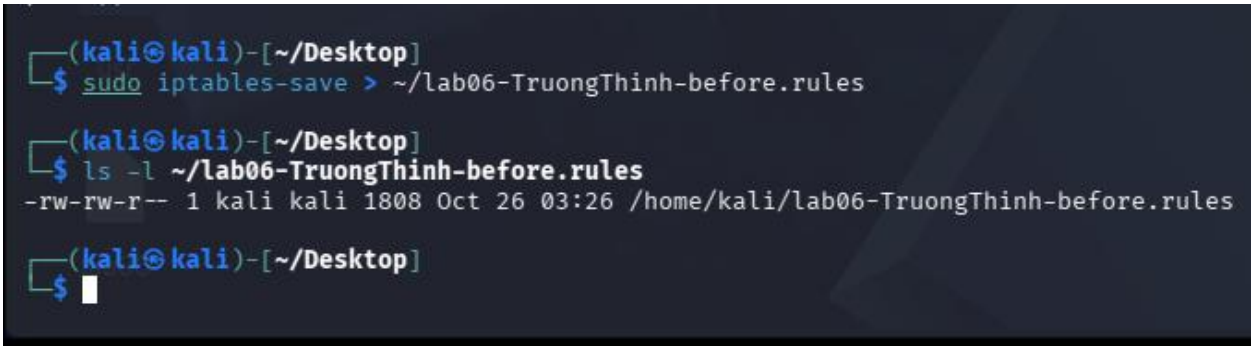
Hình 3: Kiểm tra IP máy A (192.168.44.134) và kết nối với máy B



Hình 4: Kiểm tra IP máy B (192.168.44.141) và kết nối với máy A

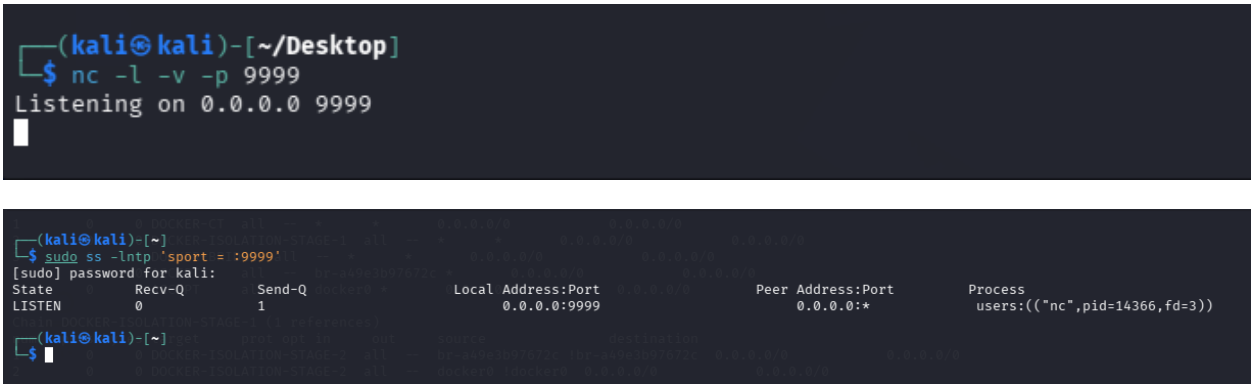


Hình 5: Kiểm tra các cổng TCP/UDP đang lắng nghe và tiến trình liên quan nếu có đủ quyền.



Hình 6: Sao lưu cấu hình IPv4 và kiểm tra file đã tạo

Tạo dịch vụ kiểm thử:



Hình 7: Trạng thái LISTEN và cổng 9999 chứng tỏ dịch vụ đã hoạt động

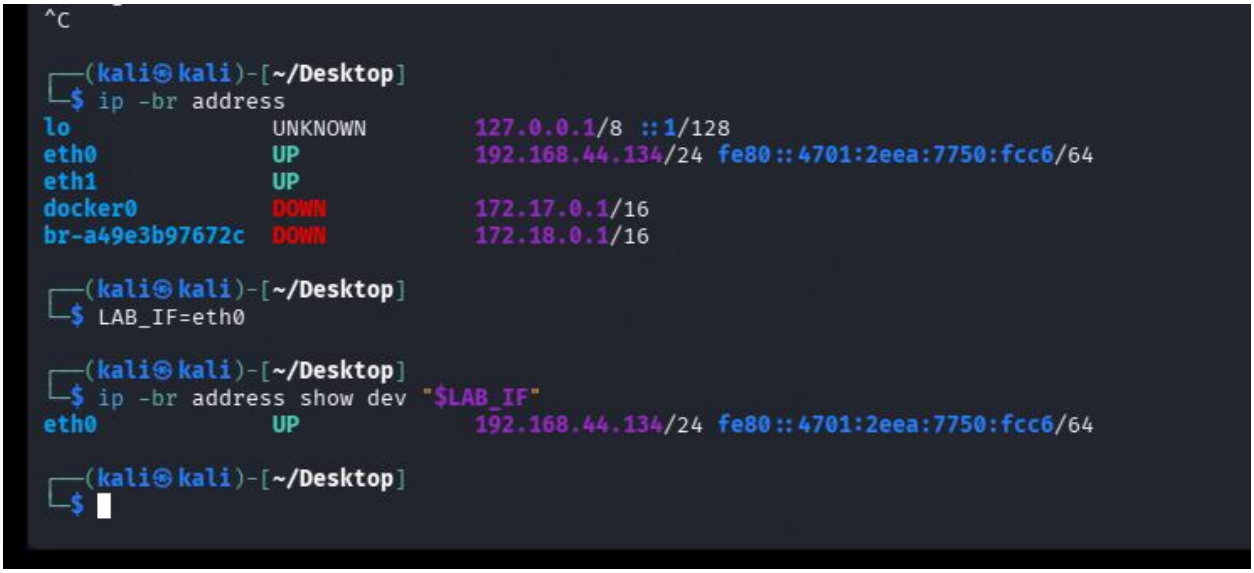


Hình 8 (Máy B - Client): Dùng lệnh nc -v 192.168.44.134 9999 kết nối thành công đến Máy A và gửi chuỗi nội dung: *"TruongThinh - Kiem tra ket noi ban dau"*.



Hình 9 (Máy A - Server): Lắng nghe trên cổng 9999 (nc -l -v -p 9999), ghi nhận kết nối đến từ Máy B (192.168.44.141) và nhận thông điệp thành công.

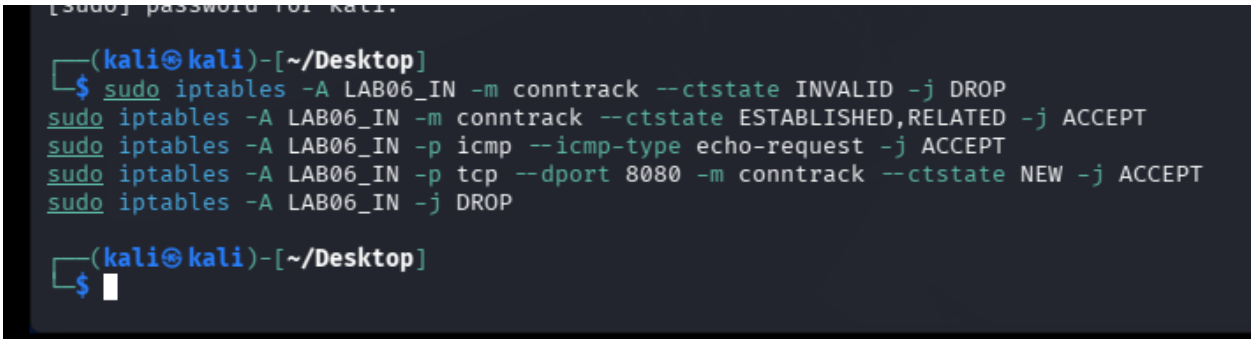
Tạo chuỗi tường lửa riêng



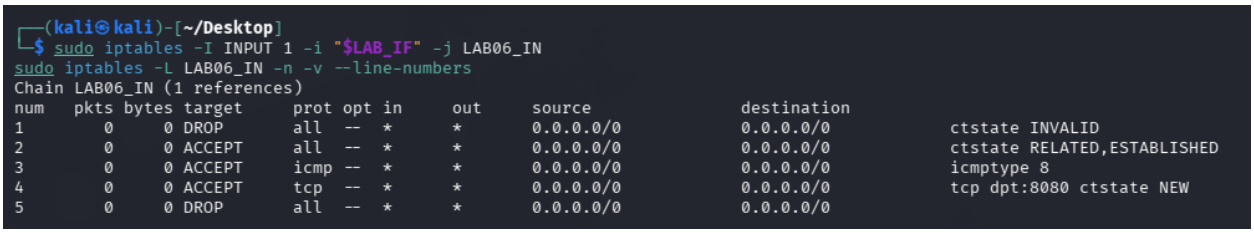
Hình 10: Đặt biến bằng tên card Host-only thực tế trên máy A và kiểm tra lại thông tin



Hình 11: Tạo chuỗi mới



Hình 12: Thêm các quy tắc



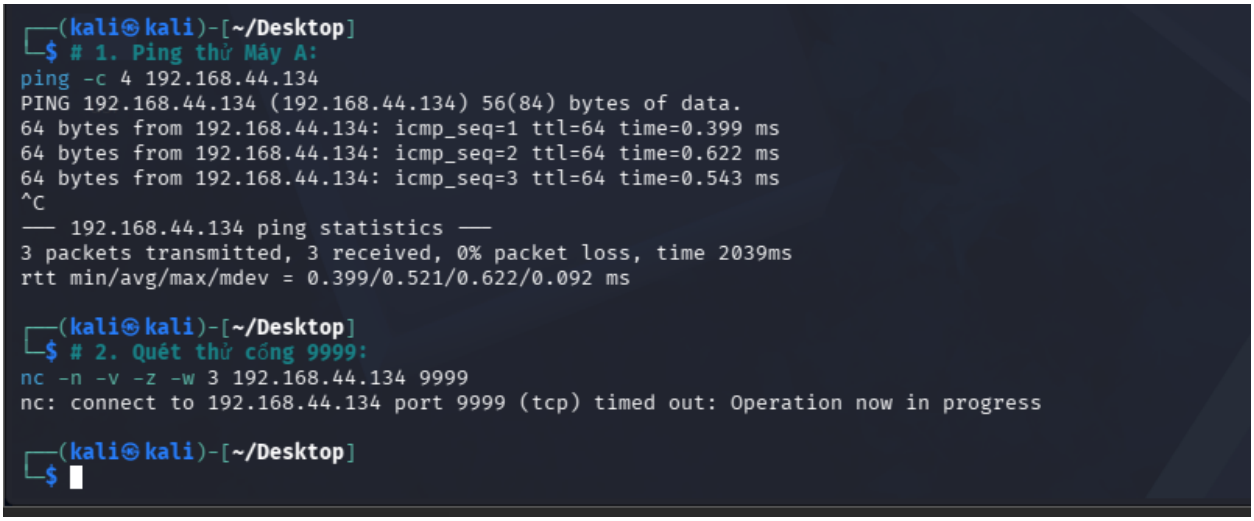
Hình 13: Áp dụng chuỗi vào INPUT và kiểm tra

Các bước cài đặt trên nhằm:

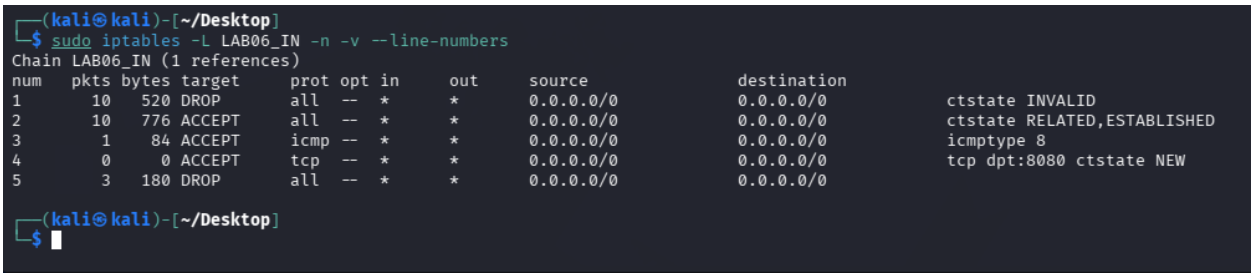
- Loại bỏ gói có trạng thái không hợp lệ.
- Cho phép lưu lượng thuộc kết nối đã thiết lập hoặc liên quan.
- Cho phép ping.
- Cho phép kết nối TCP mới đến cổng 8080.
- Chặn lưu lượng còn lại đi qua chuỗi.

Cấu hình này chỉ tác động đến lưu lượng đầu vào trên card Host-only được chọn, không phải chính sách bảo vệ toàn bộ các card mạng của máy.

Kiểm tra cổng bị chặn



Hình 14: Kiểm tra kết nối đến cổng 9999 từ máy B



Hình 15: Quan sát bộ đếm gói của quy tắc DROP cuối chuỗi trên máy A

Cho phép cổng 9999

```
┌──(kali㉿kali)-[~/Desktop]
└─$ sudo iptables -I LAB06_IN 4 -p tcp --dport 9999 -m conntrack --ctstate NEW -j ACCEPT

┌──(kali㉿kali)-[~/Desktop]
└─$ sudo iptables -L LAB06_IN -n -v --line-numbers
Chain LAB06_IN (1 references)
num   pkts bytes target     prot opt in     out     source               destination
1       10   520 DROP       all  --  *      *       0.0.0.0/0            0.0.0.0/0           ctstate INVALID
2       12   928 ACCEPT     all  --  *      *       0.0.0.0/0            0.0.0.0/0           ctstate RELATED,ESTABLISHED
3        1    84 ACCEPT     icmp --  *      *       0.0.0.0/0            0.0.0.0/0           icmptype 8
4        0     0 ACCEPT     tcp  --  *      *       0.0.0.0/0            0.0.0.0/0           tcp dpt:9999 ctstate NEW
5        0     0 ACCEPT     tcp  --  *      *       0.0.0.0/0            0.0.0.0/0           tcp dpt:8080 ctstate NEW
6        3   180 DROP       all  --  *      *       0.0.0.0/0            0.0.0.0/0
```

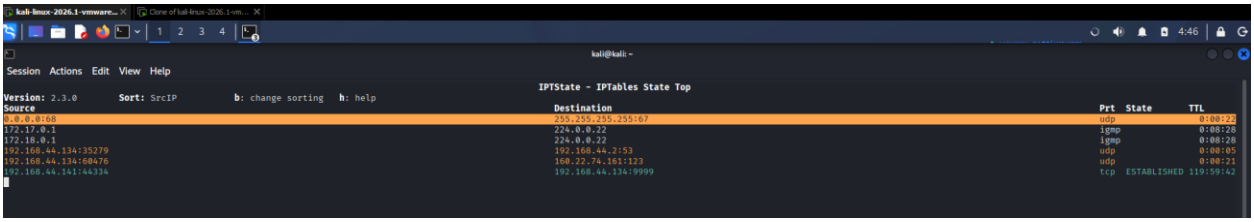
Hình 16: Chèn quy tắc cho phép kết nối mới vào cổng TCP 9999 tại dòng 4 của chuỗi LAB06_IN trên Máy A.

```
┌──(kali㉿kali)-[~/Desktop]
└─$ nc -l -v -p 9999
Listening on 0.0.0.0 9999
Connection received on 192.168.44.141 34560
LAB06 - Ket noi sau khi mo cong
```

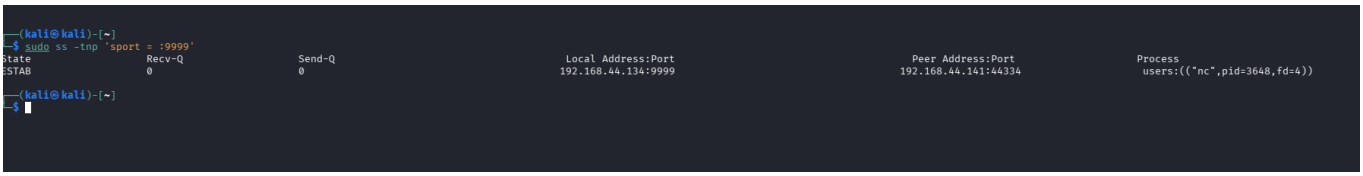
```
┌──(kali㉿kali)-[~/Desktop]
└─$ nc -n -v 192.168.44.134 9999
Connection to 192.168.44.134 9999 port [tcp/*] succeeded!
LAB06 - Ket noi sau khi mo cong
```

Hình 17: Máy B kết nối TCP cổng 9999 tới Máy A thành công và gửi dữ liệu sau khi mở cổng trên tường lửa.

Quan sát bằng iptstate



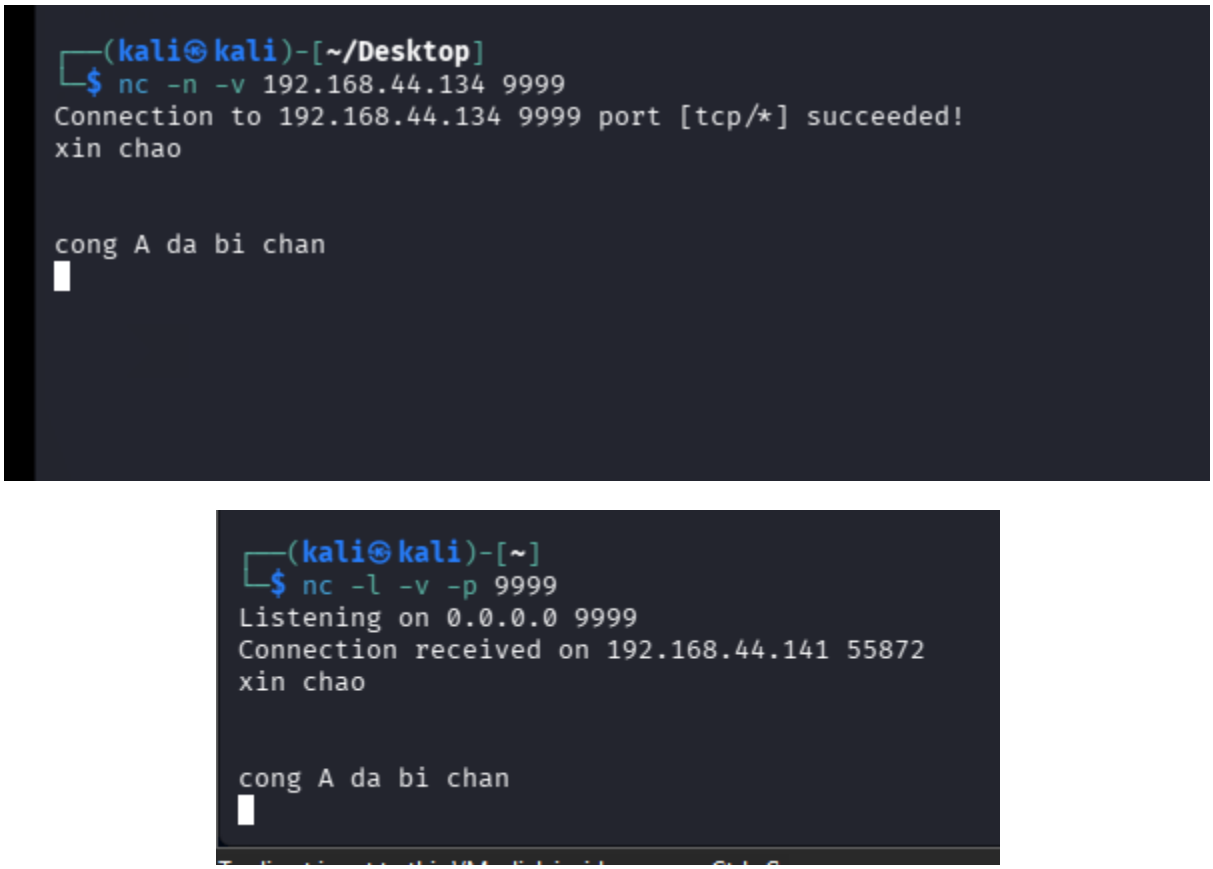
Hình 18: Giao diện iptstate ghi nhận kết nối TCP cổng 9999 từ Máy B ở trạng thái ESTABLISHED.



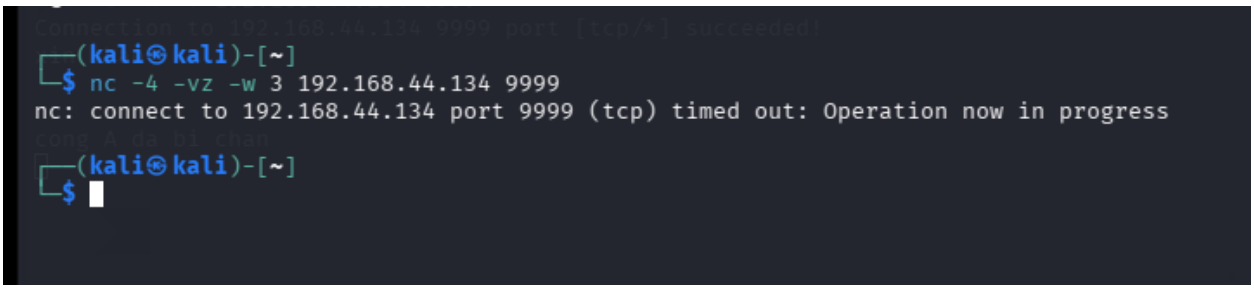
Hình 19: Đối chiếu trạng thái socket cổng 9999 bằng lệnh ss



Hình 20: Xóa rule cổng 9999 trên Máy A



Hình 21: Cửa sổ Netcat cũ trên Máy B: gõ tiếp nội dung ➔ Máy A vẫn nhận bình thường (ESTABLISHED).



Hình 22: Thử tạo kết nối mới từ Máy B tới cổng 9999 sau khi xóa rule, kết nối bị chặn và báo timeout.

6.3 TỰ ĐỘNG HÓA CÁC YÊU CẦU WEB BẰNG PYTHON

Mục tiêu: Tự động hóa gửi yêu cầu HTTP POST để kiểm thử lỗ hổng Time-Based Command Injection và đo thời gian phản hồi của máy chủ.

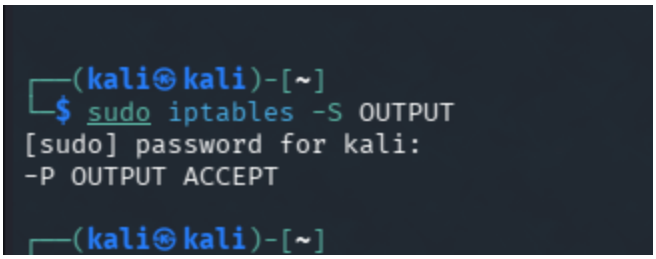
Các bước thực hiện:

1. Sử dụng công cụ DevTools (F12 Network) trên Firefox để phân tích cấu trúc yêu cầu HTTP POST gửi tới blind2.php, bao gồm URL, header và dữ liệu form (target).
2. Xây dựng script Python 3 (replay_request.py) sử dụng thư viện urllib.request để tự động hóa gửi payload độc hại với header chuẩn (identity encoding để tránh nén dữ liệu).
3. Sử dụng time.perf_counter() để đo chính xác thời gian từ lúc gửi yêu cầu đến khi nhận toàn bộ dữ liệu phản hồi.

Kết quả: Yêu cầu trả về mã trạng thái 200 OK với thời gian trễ ~9.4 giây, chứng minh điều kiện kiểm tra trên máy chủ thỏa mãn và lệnh ping gây trễ được thực thi thành công.



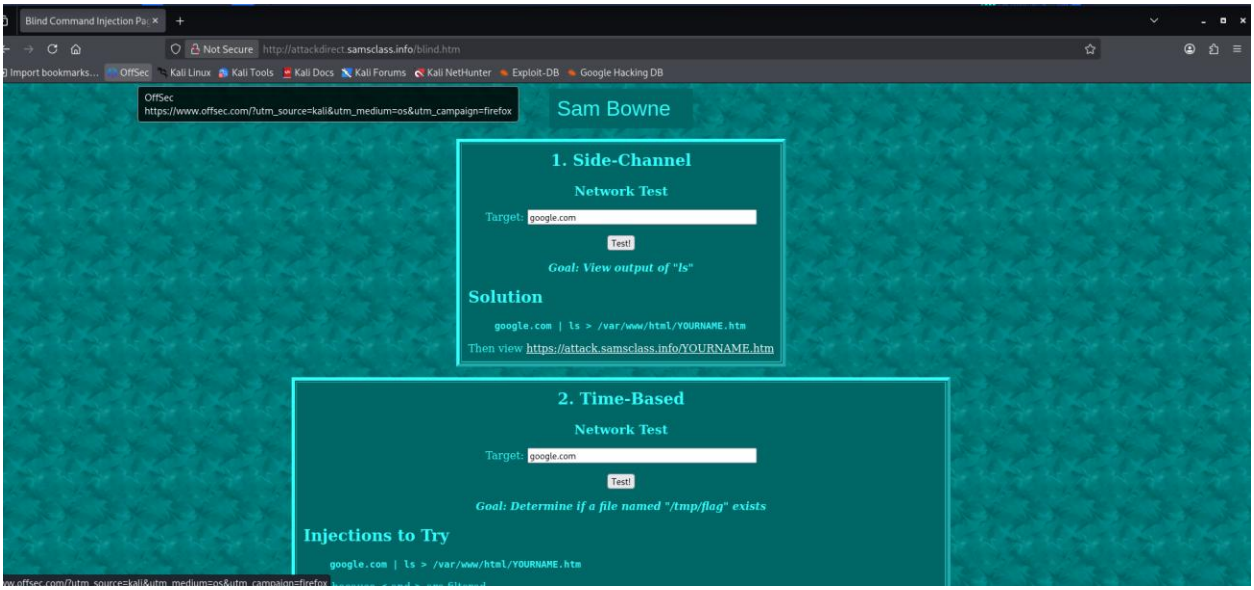
Hình 23: Kiểm tra phân giải tên miền mục tiêu bằng lệnh getent ahostsv4, phân giải thành công ra IP 198.199.94.12.



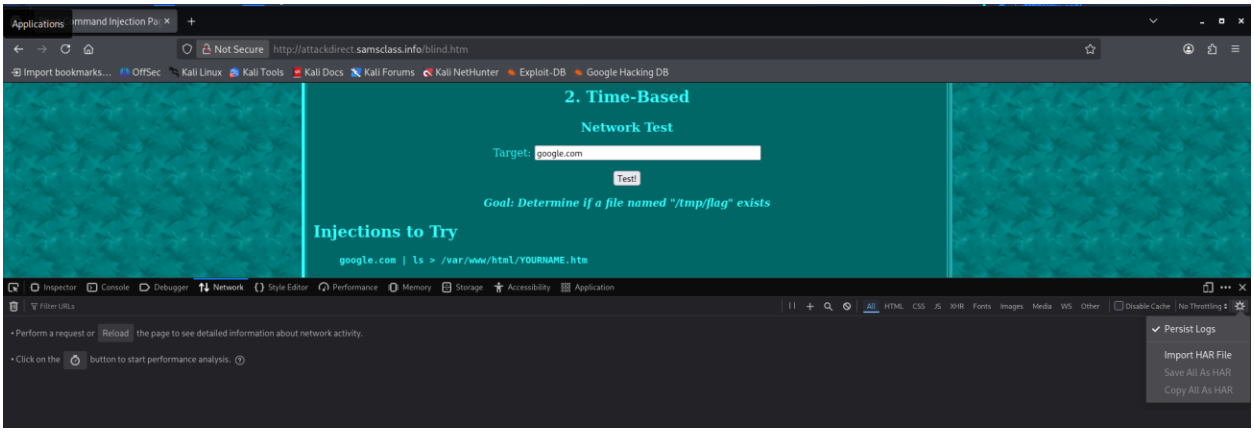
Hình 24: Kiểm tra tường lửa chiều ra



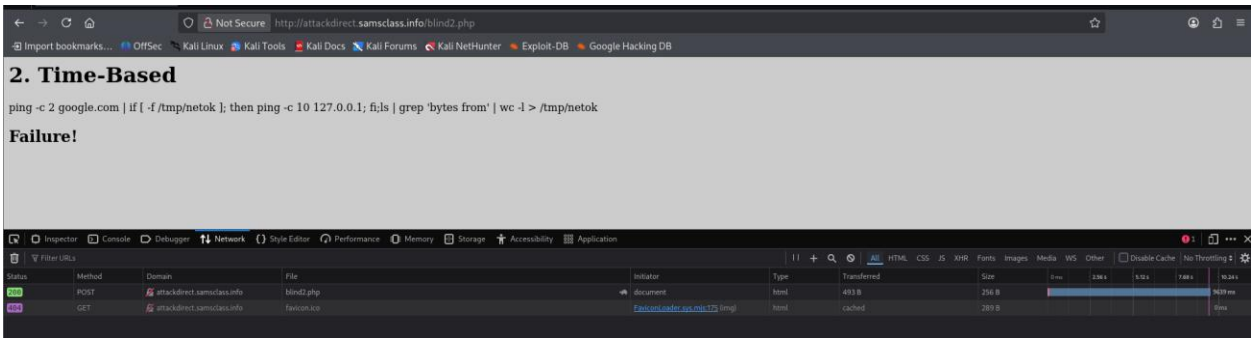
Hình 25: Kiểm tra kết nối đến website mục tiêu



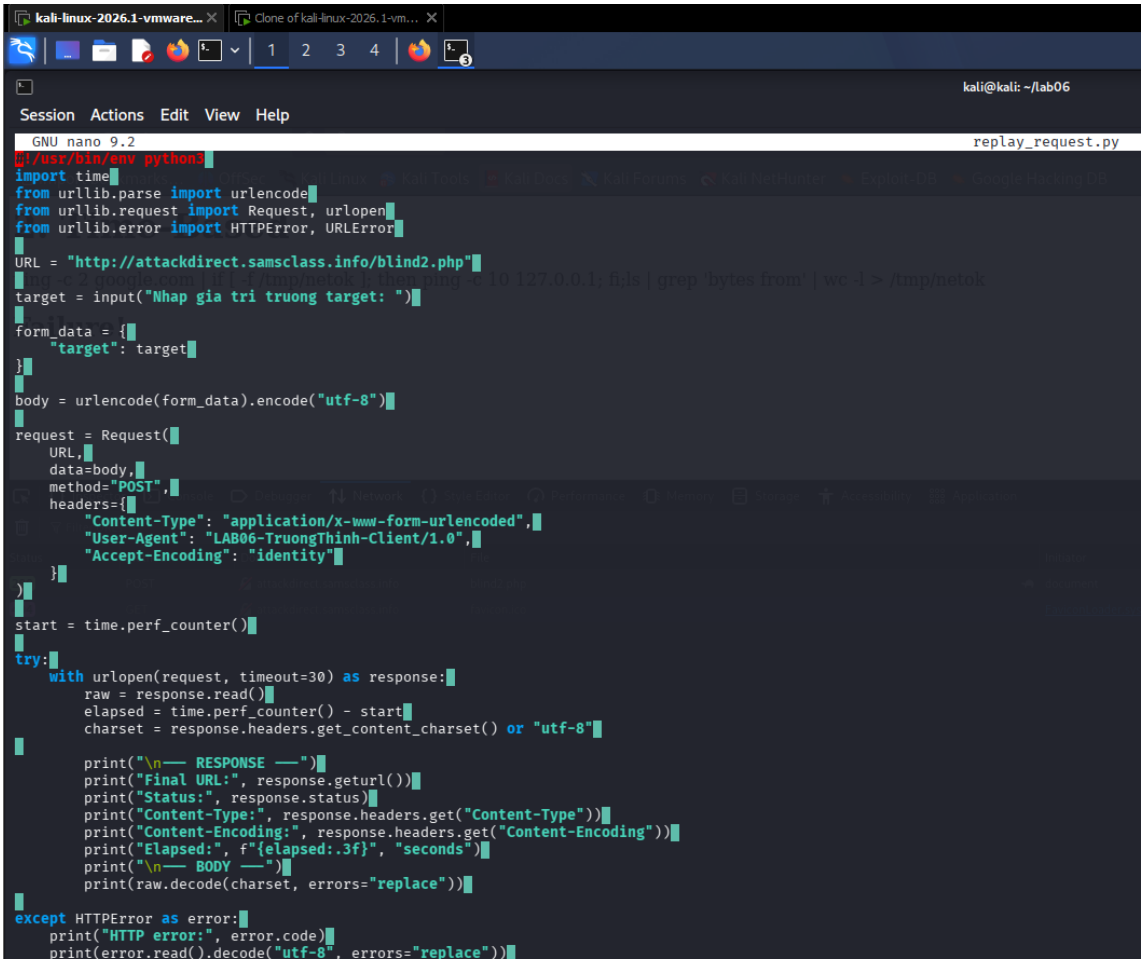
Hình 26: Truy cập đường link
http://attackdirect.samsclass.info/blind.htm



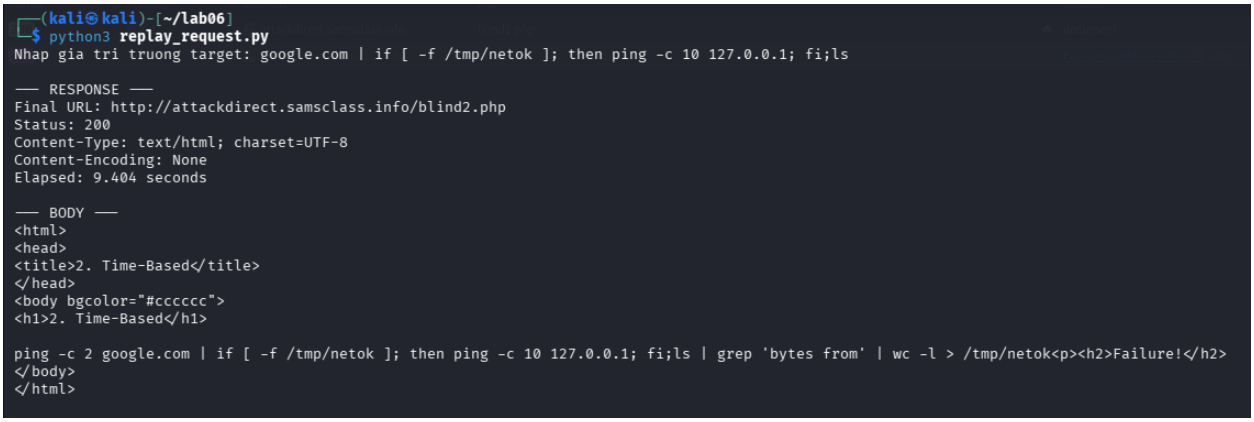
Hình 27: Phân tích yêu cầu HTTP (POST Request) bằng Firefox DevTools



Hình 28: Kiểm tra lỗ hổng Time-Based Blind Command Injection trên trình duyệt



Hình 29: Tạo script Python 3



Hình 30: Thực thi script Python gửi POST request, nhận phản hồi Status 200 với thời gian trễ 9.404s.